

ZENITH ORBITAL SYSTEMS

Cybersecurity Management Plan

Adaptive Security and Zero Trust Operations Framework (AZTOF) v2.0

Effective: April 2026 | Next Review: April 2027

Prepared by: Noe Valencia, PSSE

1. Introduction

Cybersecurity is not optional anymore. IBM reported the global average cost of a data breach hit \$4.88 million in 2024, and U.S. organizations averaged \$10.22 million per incident. Cybercrime costs as a whole are projected to hit \$10.5 trillion annually by 2025. The attack methods are not mysterious either. The human element (social engineering, errors, and credential misuse) shows up in about 60% of breaches per the 2025 Verizon DBIR, with stolen credentials at 22%, vulnerability exploitation at 20%, and phishing at 16% of initial access vectors. Ransomware showed up in 44% of breaches in the most recent Verizon DBIR, up from 32% the year before. Attackers are also getting faster. The median time from initial access to ransomware execution dropped to just five days in 2025. Identity attacks account for nearly 90% of incident response cases, and 97% of those use nothing more than stolen or guessed passwords.

The frameworks we use to manage these risks have been updated too. NIST released CSF 2.0 in February 2024. The biggest change was adding a sixth function called Govern, which puts cybersecurity governance at the same level as any other enterprise risk. CISA updated their Zero Trust Maturity Model to version 2.0. The CISA Known Exploited Vulnerabilities catalog grew to 1,484 entries by end of 2025, a 20% jump from the year before.

This Cybersecurity Management Plan is built around the Adaptive Security and Zero Trust Operations Framework, or AZTOF. It pulls from NIST CSF 2.0, NIST SP 800-207, CISA ZTMM 2.0, and MITRE ATT&CK. Fayol's five management functions (Forecasting, Planning, Organizing, Coordinating, and Controlling) are used to manage each of the six AZTOF domains. For ZOS, the stakes are elevated beyond the standard enterprise context: a cybersecurity failure is not just a data breach, it is a potential loss of command authority over hardware in orbit.

The six domains covered in this plan are:

- Identity and Access Governance (IAG)
- Threat Detection and Incident Response (TDIR)
- Data Protection and Privacy (DPP)
- Vulnerability and Configuration Management (VCM)
- Regulatory Compliance and Audit Readiness (RCAR)
- Security Culture and Workforce Resilience (SCWR)

2. AZTOF Governance Framework

2.1 Framework Foundations

AZTOF is built on four current frameworks. Each one was picked because it addresses something specific and relevant to ZOS operations.

NIST Cybersecurity Framework 2.0 (Released February 26, 2024): This is the most significant update to the CSF since it was first published in 2014. The big change is the new Govern function. It sits at the center of the framework and connects to all five other functions. That placement is intentional. It signals that governance is not a supporting activity, it is the core. CSF 2.0 also expanded scope so it applies to all organizations, not just critical infrastructure. AZTOF maps all six of its domains to the CSF 2.0 functions.

NIST SP 800-207 (Zero Trust Architecture): NIST SP 800-207 defines Zero Trust through seven tenets. The core idea is that no user, device, or network is trusted by default. Access is granted per session based on dynamic policy and continuous verification. AZTOF's Identity and Access Governance domain is built directly on these principles.

CISA Zero Trust Maturity Model 2.0: CISA's ZTMM 2.0 breaks Zero Trust down into five pillars: Identity, Devices, Networks, Applications and Workloads, and Data. The model defines four maturity stages: Traditional, Initial, Advanced, and Optimal. AZTOF uses the ZTMM 2.0 as the Zero Trust maturity assessment tool. The ZOS target is reaching the Advanced stage across all five pillars within 36 months.

MITRE ATT&CK Enterprise Framework: MITRE ATT&CK is a catalog of real adversary tactics, techniques, and procedures based on observed attacks. AZTOF uses it for threat modeling, detection gap analysis, and red and purple team exercise design. Mapping Splunk SIEM detection rules to ATT&CK techniques gives a structured way to find and close blind spots in detection coverage.

2.2 AZTOF Domain Descriptions

Domain 1: Identity and Access Governance (IAG): IAG covers who and what can access ZOS systems, data, and resources. Given that 97% of identity attacks use stolen or guessed passwords and identity weaknesses show up in nearly 90% of IR investigations, this is the highest-impact domain in the framework. IAG enforces MFA for everyone, implements privileged access management, pushes toward phishing-resistant FIDO2 authentication for high-privilege roles, and manages the full identity lifecycle from hire to termination.

Domain 2: Threat Detection and Incident Response (TDIR): TDIR covers the ability to detect attacks through Splunk SIEM and Huntress EDR tools mapped to MITRE ATT&CK, triage and validate alerts through a SOC function, contain and eradicate threats, and recover in a controlled and documented way. With ransomware executing in a median of five days from initial access, detection speed directly determines how bad the outcome is for ZOS mission continuity.

Domain 3: Data Protection and Privacy (DPP): DPP covers how ZOS data is classified, protected, and processed throughout its lifecycle. For ZOS, data includes

mission-critical satellite telemetry, defense client relay data, personnel records, and financial information. Each data type carries different regulatory obligations and operational sensitivity.

Domain 4: Vulnerability and Configuration Management (VCM): VCM covers how ZOS identifies, prioritizes, and remediates vulnerabilities and configuration weaknesses across its entire asset inventory. Given that ZOS operates infrastructure where a single exploited vulnerability could compromise satellite command capability, VCM is a mission-critical function, not a routine IT task.

Domain 5: Regulatory Compliance and Audit Readiness (RCAR): RCAR covers how ZOS maintains compliance with applicable regulatory frameworks and prepares for internal and external audits. For ZOS, compliance obligations include CMMC Level 2 (defense client contracts), NIST CSF 2.0, CIS Controls v8, and the Texas Data Privacy and Security Act.

Domain 6: Security Culture and Workforce Resilience (SCWR): SCWR recognizes that technology controls are only as effective as the people operating within them. Human error, social engineering, and insider threat collectively account for a majority of breaches. SCWR builds security awareness, instills secure behaviors, and ensures ZOS personnel are prepared to recognize and respond to threats.

3. Fayol's Management Functions Applied to Each AZTOF Domain

3.1 Identity and Access Governance (IAG)

Threat context: Identity attacks account for 65% of initial access in IR investigations. Modern MFA prevents more than 99% of identity-based attacks. Despite that, cloud identities are found to be over-permissioned in 99% of large-sample audits. The least-privilege gap is real and widespread.

Forecasting: Quarterly threat intelligence reviews will track emerging identity attack methods including adversary-in-the-middle phishing, SIM swapping, and session token hijacking. ZOS will subscribe to CISA advisories and relevant ISAC feeds for early warning. Annual MFA coverage audits will measure the gap between current enrollment and the 100% target across all user types. CISA ZTMM 2.0 Identity pillar maturity assessments will define the roadmap to the next stage.

Planning: An annual Identity Security Roadmap will prioritize: getting MFA to 100% across all user types; migrating high-privilege accounts to FIDO2 phishing-resistant authenticators; deploying CyberArk PAM covering all privileged accounts; and formalizing RBAC matrices with documented access request, approval, and review workflows. Conditional access policies will enforce device compliance as a condition of network access per NIST SP 800-207.

Organizing: An Identity Governance team will be established in the ZOS IT Security function. It will include an IAM Engineer who handles directory services, provisioning, and MFA platform management, and a Privileged Access Administrator who runs the CyberArk PAM tool and monitors privileged sessions. RACI matrices will define ownership for every identity governance process.

Coordinating: IAG activities will be formally tied into HR's joiner, mover, and leaver processes with automated triggers for provisioning, access changes, and deprovisioning. The target is under four hours from termination notification to account deactivation. Legal and Procurement will set contractual identity standards for vendors so third-party access stays least-privilege. A quarterly Identity Review Board with IT Security, HR, Legal, and Business Unit leads will govern access exceptions.

Controlling: Monthly access certifications reviewing all active accounts and their permissions. Dormant accounts flagged for review after 30 days of inactivity. 100% MFA enrollment target tracked monthly. Monthly CISO reporting on IAG KPIs including privileged account count, deprovisioning SLA compliance, and MFA enrollment rate.

3.2 Threat Detection and Incident Response (TDIR)

Threat context: Ransomware showed up in 44% of breaches in the 2025 Verizon DBIR. Attackers are deploying ransomware in a median of five days from initial access. For ZOS, a ransomware event affecting ground station systems during an active mission could result in loss of satellite command capability.

Forecasting: CTI program with CISA KEV and MITRE ATT&CK threat modeling. Annual tabletop exercises and 18-month red/purple team exercises. ZOS-specific threat scenarios include satellite ground station targeting, SDR interface exploitation, and terrestrial API attacks against ZOS client-facing systems.

Planning: Comprehensive Incident Response Plan developed, reviewed annually, and exercised twice a year. The IRP defines five severity levels (P1 through P5), escalation paths, communication templates, regulatory notification timelines, and recovery time objectives per system tier. A dedicated ransomware playbook addresses double-extortion scenarios including data exfiltration before encryption, negotiation decision criteria, and backup-based recovery. AI-driven detection built into Splunk SIEM to reduce mean time to detect.

Organizing: Virtual SOC staffed by in-house Tier 1 analysts with Huntress MDR covering Tier 2 and Tier 3 escalations and 24/7 monitoring. Pre-constituted IRT with defined roles: IRM (Noe Valencia), Mission Assurance Director (Michael R. Torres), Technical Lead (Carlos E. Mendoza), Communications Lead (Sandra L. Pham), and Legal/Compliance Liaison (Gregory A. Whitfield). All IRT members participate in at least two exercises per year. On-call schedules, out-of-band communication channels, and escalation contact trees are documented, tested, and updated quarterly.

Coordinating: TDIR coordinated with Business Continuity Management to ensure the IRP and BCP align and that RTO and RPO targets are consistent. Pre-established protocols with the FBI Cyber Division (IC3), CISA, and external cybersecurity legal counsel are in place before any incident happens. Splunk SIEM ticketing integrates with IT Operations workflows so remediation actions move through the change management process. Post-incident communications are reviewed by Legal before any external disclosure.

Controlling: Monthly SOC Metrics Dashboard tracks: MTTD by severity (P1 target under 30 minutes); MTTR by severity (P1 target under 4 hours); false positive rate (target under 20%); and incident recurrence rate (target zero for closed incidents).

Mandatory Post-Incident Reviews completed within 5 business days for all P1 and P2 incidents. Semi-annual IRP exercises include at least one unannounced drill per year.

3.3 Data Protection and Privacy (DPP)

Forecasting: Annual data discovery and classification review to identify new data types and update classification. Regulatory horizon calendar maintained 180+ days ahead for GDPR, HIPAA, TDPSA, and CMMC updates. Data breach trend analysis from Verizon DBIR and IBM Cost of a Breach Report informs ZOS DPP priority setting.

Planning: Four-tier data classification policy (Mission Critical, Confidential, Internal, Public) with corresponding handling requirements. AES-256 encryption at rest and TLS 1.3 in transit as the ZOS baseline. Data Protection Impact Assessment (DPIA) process for new data processing activities. Data Processing Agreements (DPAs) and Business Associate Agreements (BAAs) scheduled and tracked.

Organizing: Data Protection Officer (DPO) function established within ZOS IT Security. Embedded business unit data stewards accountable for classification and handling within their functions. Zscaler CASB deployed for DLP monitoring and control. All new vendors must pass a security assessment before receiving access to ZOS data.

Coordinating: Legal engagement for BAA and GDPR obligations. Procurement enforces DPA requirements as a contract condition. DPP activities integrated with TDIR IRP so data breach response procedures align with classification and regulatory notification requirements.

Controlling: Monthly DLP exception review. 100% encryption target for all data in transit and at rest. Annual privacy audits. Third-party attestation tracking for all Tier 1 CSPs.

3.4 Vulnerability and Configuration Management (VCM)

Forecasting: CISA KEV catalog monitored multiple times per week. CMDB cross-referencing ensures all assets are tracked. NVD and vendor advisory feeds subscribed for ZOS-relevant technologies including Palo Alto, Cisco, Dell, and Meraki.

Planning: KEV 48-hour remediation SLA for all CISA KEV-listed vulnerabilities. Critical (non-KEV) 15-day SLA. High 30-day SLA. Medium 90-day SLA. CIS Benchmark-aligned configuration baselines for all ZOS network device types. Annual third-party penetration test required.

Organizing: Vulnerability Management Engineer role established in IT Security. Qualys VMDB deployed across all 500+ ZOS assets. CMDB maintained and current. Monthly Configuration Compliance Working Group reviews drift reports and assigns remediation owners. DevSecOps integration extends secure configuration standards into ZOS operational systems.

Coordinating: VCM integrates with the IT Change Management process so patches deploy through controlled change windows. Emergency change procedures pre-defined for KEV and critical actively exploited vulnerabilities, allowing accelerated deployment with appropriate approvals. VCM coordinates with TDIR so that any KEV-listed

vulnerability affecting the ZOS environment triggers threat hunting in the vSOC concurrently with patching.

Controlling: Monthly vulnerability dashboards report open findings by severity and SLA status, patch coverage by asset tier, and KEV remediation compliance. Configuration compliance scans run weekly with automated reports to system owners for any drift. KPIs: KEV 48-hour remediation compliance target 100%; Critical SLA compliance target over 95%; assets with verified baseline configuration target over 98%; open critical findings older than 15 days target zero.

3.5 Regulatory Compliance and Audit Readiness (RCAR)

Forecasting: Regulatory horizon calendar tracks proposed rules, effective dates, and projected compliance gaps, with legal counsel engaged for regulatory changes that have 12 to 18 months of lead time. Cyber insurance renewal cycles serve as structured forcing functions to assess and demonstrate compliance posture improvements. ZOS compliance obligations: HIPAA for healthcare data handling, GDPR and CCPA for personal data, CMMC Level 2 for defense contracts, and TDPSA for Texas operations.

Planning: Annual Compliance Work Plan maps all applicable regulatory requirements to specific AZTOF controls, assigns control owners, and schedules internal audits and external assessments. Continuous Controls Monitoring through Archer GRC automates evidence collection for SOC 2 and applicable compliance controls. The control library aligns to NIST CSF 2.0, which cross-references ISO 27001, CIS Controls, and the HIPAA Security Rule so ZOS gets multi-framework coverage efficiently.

Organizing: Compliance and Risk Manager established in the ZOS IT Security function with dotted-line reporting to Legal. This role owns the Risk Register, coordinates internal audits, manages relationships with external auditors, and handles regulatory inquiries. Archer GRC is the system of record for policies, controls, evidence, risk register entries, and audit findings.

Coordinating: Finance reflects cybersecurity compliance obligations in budgeting and cyber insurance requirements. Procurement enforces third-party compliance requirements as a contract condition. The Compliance and Risk Manager presents the compliance posture to ZOS executive leadership and the board quarterly, consistent with CSF 2.0's Govern function requirement for leadership engagement.

Controlling: Annual SOC 2 audit. CMMC Level 2 assessment. Internal audit findings tracked to closure in Archer GRC. External auditor relationships managed with defined engagement timelines.

3.6 Security Culture and Workforce Resilience (SCWR)

Forecasting: Annual phishing susceptibility baseline measurement using KnowBe4 simulations. Workforce risk profiling to identify departments and roles with elevated social engineering exposure. Security culture survey administered annually to measure attitudes, behaviors, and knowledge gaps. AI-driven phishing campaign data reviewed quarterly to update simulation scenarios.

Planning: KnowBe4 quarterly training calendar with role-specific content for general staff, IT administrators, executives, and new hires. Biannual IRT tabletop exercise schedule including at least one unannounced drill per year. New hire security onboarding completed before first system access is granted. Executive security briefing program to ensure leadership understands the ZOS threat landscape.

Organizing: Security Awareness Lead designated within ZOS IT Security. KnowBe4 platform managed by the Security Awareness Lead. Phishing simulation campaign library maintained and rotated quarterly to prevent habituation. Role-based training tracks developed for general staff, system administrators, finance, and HR.

Coordinating: HR integration for new hire onboarding ensures all new ZOS employees complete security training before receiving access credentials. Security culture data coordinated with TDIR for exercise scenario development and post-incident lessons learned. Annual security awareness report shared with ZOS executive leadership.

Controlling: Monthly phishing click rate tracked by department (target below 5%). Quarterly training completion rate (target 100% within 30 days of assignment). Exercise after-action reports reviewed by IRM and IT Security Manager within 10 business days of exercise completion. Annual security culture survey results reported to executive leadership.

4. AZTOF Governance Summary Matrix

This table summarizes Fayol's five management functions across all six AZTOF domains. It is the quick-reference governance tool for the CISO, executive leadership, and auditors.

DOMAIN	FORECASTING	PLANNING	ORGANIZING	COORDINATING	CONTROLLING
IAG	Quarterly identity threat reviews; CISA ZTMM Identity pillar assessment; MFA coverage gap analysis	Annual Identity Security Roadmap; FIDO2 for privileged roles; RBAC matrices with access workflows	IAM Engineer and Privileged Access Admin; CyberArk PAM deployment; Okta SSO and lifecycle platform	HR joiner/mover/leaver integration; under 4 hour deprovisioning SLA; quarterly Identity Review Board	Monthly access certifications; dormant account flagging; 100% MFA target; monthly CISO reporting
TDIR	CTI program with CISA KEV and MITRE ATT&CK; annual tabletop; 18-month red/purple team exercises	IRP with P1 through P5 severity levels; ransomware double-extortion playbook; regulatory notification timelines	vSOC with 24/7 Huntress MDR partner; pre-constituted IRT with defined roles; out-of-band comms tested quarterly	Integrated with BCM; pre-established FBI IC3, CISA, and legal counsel protocols; Splunk SIEM to ITSM ticketing	P1 MTTD under 30 min; P1 MTTR under 4 hours; mandatory PIRs within 5 days; semi-annual IRP exercises
DPP	Annual data discovery and classification; regulatory horizon	4-tier classification policy; AES-256 and TLS 1.3	DPO and embedded data stewards; DLP tooling; vendor	Legal for BAA and GDPR; Procurement for vendor risk; integrated with TDIR IRP	Monthly DLP exception review; 100% encryption target; annual privacy

	calendar 180+ days ahead	standards; DPIA process; DPA and BAA schedule	security assessment before onboarding		audits; third-party attestation tracking
VCM	CISA KEV catalog monitoring multiple times per week; CMDB cross-referencing; NVD and vendor advisory feeds	KEV 48-hour SLA; Critical 15-day SLA; High 30-day SLA; CIS Benchmark baselines	Vulnerability Management Engineer; Qualys VMDR deployment; CMDB maintained; monthly Compliance Working Group	Patch windows coordinated with IT Operations; emergency change procedures for KEV; VCM coordinates with TDIR	Weekly Qualys scan reports; monthly vulnerability trend analysis; annual pen test findings review; KPI dashboards
RCAR	Regulatory horizon calendar 180+ days ahead; cyber insurance renewal as forcing function	Annual Compliance Work Plan; continuous controls monitoring via Archer GRC; multi-framework alignment	Compliance and Risk Manager; Archer GRC as system of record; external auditor relationships managed	Finance for budgeting obligations; Procurement for third-party compliance; quarterly board reporting	Annual SOC 2 audit; CMMC Level 2 assessment; internal audit findings tracked to closure in GRC
SCWR	Annual phishing susceptibility baseline; workforce risk profiling; security culture survey	KnowBe4 quarterly training calendar; biannual IRT tabletop exercise schedule; new hire security onboarding	Security Awareness Lead; KnowBe4 platform managed; phishing simulation campaign library maintained	HR integration for new hire onboarding; coordinated with TDIR for exercise scenarios and lessons learned	Monthly phishing click rate tracked; quarterly training completion rate; exercise after-action reports reviewed

5. Conclusion

The threat environment is not slowing down. Global average breach costs hit \$4.88 million in 2024. Ransomware showed up in 44% of breaches. Attackers are deploying ransomware in a median of five days from initial access. CISA added 245 new confirmed-exploited vulnerabilities to their catalog in 2025 alone. AI now drives over 80% of phishing campaigns. These are not projections. They are current data points.

AZTOF is built to address this environment directly. It pulls from NIST CSF 2.0 including the new Govern function, CISA's Zero Trust Maturity Model 2.0, NIST SP 800-207, and MITRE ATT&CK. The six governance domains cover identity, detection and response, data protection, vulnerability management, compliance, and workforce resilience. Fayol's management functions make sure each domain is run with clear ownership, defined activities, and measurable outcomes.

For ZOS, AZTOF is not just a compliance framework. It is the governance structure that protects the ground infrastructure supporting every orbital mission we manage. This plan gets reviewed annually. The CISO leads the review with executive leadership and the board in line with CSF 2.0's Govern function requirements. As the threat environment changes, as regulations update, and as ZOS grows, the specific activities

within each AZTOF domain get updated to match. The framework stays stable. The activities inside it stay current.

6. References and Sources

- NIST CSF 2.0. February 26, 2024. <https://csrc.nist.gov/pubs/cswp/29>
- NIST SP 800-207: Zero Trust Architecture. 2020.
- NIST NCCoE SP 1800-35: Implementing a Zero Trust Architecture. June 2025.
- CISA Zero Trust Maturity Model v2.0. April 2023. <https://www.cisa.gov/zero-trust-maturity-model>
- CISA Known Exploited Vulnerabilities (KEV) Catalog. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- IBM Security. Cost of a Data Breach Report 2024. 2024.
- Verizon. 2025 Data Breach Investigations Report (DBIR). 2025.
- Sophos. State of Ransomware 2025. 2025.
- IBM X-Force. Threat Intelligence Index 2025. 2025.
- MITRE ATT&CK Enterprise Framework. <https://attack.mitre.org>